

REPORTE EJECUTIVO: GESTIÓN DE RIESGOS DE CIBERSEGURIDAD

Evaluación Inicial, Top de Riesgos y Plan de Inversión Estratégico

Dirigido a la Dirección General y Comisión Directiva

Elaborado por: Tomas Serrani (CISO / Resp. de Seguridad)
Organización: Clínica Privada (120 empleados, 800 pacientes/día)
Fecha: 3 de septiembre de 2026

Resumen Ejecutivo para la Gerencia

Tras la auditoría externa recibida, se realizó un análisis integral sobre la infraestructura tecnológica de la clínica. Los resultados indican una vulnerabilidad crítica ante ataques de **Ransomware** y **Phishing**, los cuales amenazan la continuidad operativa de las Historias Clínicas Digitales (HCD) y el cumplimiento de la Ley de Protección de Datos Personales. Se presenta un plan prioritario de mitigación enfocado en tres proyectos inmediatos con una inversión estimada de **USD 6,500**.

1. Top 5 Riesgos Críticos Identificados

De un total de 7 riesgos evaluados en la plataforma SimpleRisk, se han priorizado los 5 de mayor exposición operativa y financiera:

ID	Descripción del Riesgo	Prob.	Impacto	Nivel de Riesgo
R01	Ransomware en HCD: Cifrado malicioso de la base de datos de pacientes y parálisis del centro médico.	Probable (4)	Catastrófico (5)	Crítico (20)
R02	Phishing a Personal: Robo de credenciales de facturación/admisión mediante ingeniería social.	Probable (4)	Mayor (4)	Crítico (16)
R03	Falta de MFA en Portal: Acceso no autorizado de terceros a Historias Clínicas desde internet.	Posible (3)	Catastrófico (5)	Alto (15)
R04	Corte Eléctrico Prolongado: Caída de servidores y turnos por capacidad insuficiente de UPS.	Posible (3)	Mayor (4)	Alto (12)
R05	Falla en Backups: Imposibilidad de restauración por copias de seguridad corruptas o no probadas.	Posible (3)	Mayor (4)	Alto (12)

Tabla 1: Principales amenazas detectadas en la infraestructura clínica

2. Estado de los Planes de Acción Propuestos

Para reducir la exposición en los activos críticos a niveles aceptables, se han formalizado tres planes de tratamiento inmediatos:

1. PA-01: Protección EDR y Copias Inmutables contra Ransomware (Riesgo R01)

- *Acción:* Despliegue de detección de amenazas EDR en endpoints y almacenamiento de copias inmutables (WORM) fuera de línea.
- *Responsable:* Director de IT | *Plazo:* 30 días | *Presupuesto:* USD 4,500.

2. PA-02: Implementación de Autenticación Multifactor - MFA (Riesgos R02 y R03)

- *Acción:* Forzar uso obligatorio de segundo factor de autenticación en correos y portal médico.
- *Responsable:* CISO / Resp. de Seguridad | *Plazo:* 15 días | *Presupuesto:* USD 1,200.

3. PA-03: Programa de Concientización y Simulaciones de Phishing (Riesgo R02)

- *Acción:* Capacitación obligatoria al personal médico y administrativo con simulaciones periódicas de correos maliciosos.
- *Responsable:* Resp. de Seguridad | *Plazo:* 45 días | *Presupuesto:* USD 800.

3. Recomendaciones Estratégicas para la Dirección

- **Aprobación Presupuestaria:** Liberación de USD 6,500 para la ejecución inmediata de los tres planes de mitigación presentados.
- **Política de Autenticación:** Emitir una directiva institucional aprobando la obligatoriedad del uso de MFA para todo el personal de la clínica.
- **Auditoría de Seguridad Física:** Evaluar periódicamente la seguridad física de la sala de servidores, garantizando control de accesos biométrico, redundancia energética y sistemas de detección y extinción automática de incendios por gas inerte.

Tomas Serrani
CISO / Resp. de Seguridad

Dirección General
Clínica Privada